

Alexander Engelhardt Exercise Sheet 02

1. Schneebeli AG: Ransomware attack on 01. June 2026.

You can find reports on companies in Switzerland on sites such as <https://www.ransomware.live/>, searching for the country "Switzerland" on the "Victims" tab. Because it scrapes the internet for leaked data, it can only be verified by doing intense research like searching up cross-referencing sheets, searching the Dark Web or official company confirmation.

Description of attack: Schneebeli AG was targeted by the ransomware company AiLock threatening to release sensitive information unless the specified sum has been paid to the contact information.

They overcome security mechanisms by applying an infostealer which gives them elevated privileges and thus bypass the firewall because of being perceived as a trusted source.

It could've been prevented by e.g. applying multi-factor authentication, doing backups or monitoring leakages.

2.

2.1. 119: Common situational picture 2021 page 6.

2.2. A botnet is if many infected systems are being exploited for malicious purposes. The operating systems most targeted by botnet attacks are Microsoft systems and Android devices:

https://www.bsi.bund.de/DE/Themen/Verbraucherinnen-und-Verbraucher/Cyber-Sicherheitslage/Methoden-der-Cyber-Kriminalitaet/Botnetze/botnetze_node.html

2.3. They, for one, apply social engineering (faking email senders, faking emails) to circumvent the spam filter and bait the recipient in engaging in vulnerable activity like opening infected documents or clicking on infected / malicious links.

"Fortschrittliche Angriffe

Neue Qualität aktueller Angriffe und Prognose" page 1, March 2021

2.4. I. Basic Protection:

CON.3.A1: Erhebung der Einflussfaktoren für Datensicherungen (B)

[Fachverantwortliche, IT-Betrieb]

CON.3.A2: Festlegung der Verfahrensweisen für die Datensicherung (B)

[Fachverantwortliche, IT-Betrieb]

CON.3.A4: Erstellung von Datensicherungsplänen (B) [IT-Betrieb]

CON.3.A5: Regelmäßige Datensicherung (B) [IT-Betrieb, Mitarbeitende]

CON.3.A12: Sichere Aufbewahrung der Speichermedien für die Datensicherungen (B) [IT-Betrieb]

CON.3.A14: Schutz von Datensicherungen (B) [IT-Betrieb]

CON.3.A15: Regelmäßiges Testen der Datensicherungen (B) [IT-Betrieb]

II. Standard Protection:

CON.3.A6: Entwicklung eines Datensicherungskonzepts (S)

[Fachverantwortliche, IT-Betrieb]

CON.3.A7: Beschaffung eines geeigneten Datensicherungssystems (S) [IT-Betrieb]

CON.3.A9: Voraussetzungen für die Online-Datensicherung (S) [IT-Betrieb]

III. Increased Protection:

CON.3.A13: Einsatz kryptografischer Verfahren bei der Datensicherung (H) [IT-Betrieb]

3. I. EUVD-2025-35200, CVSS Base Score v.3.1: 8.9

Description: Cross-site scripting in the Moodle GeniAI plugin: "An authenticated user with Teacher role can upload a PDF containing embedded JavaScript. The assistant outputs a direct HTML link to the uploaded file without sanitization. When other users (including Students or Administrators) click the link, the payload executes in their browser."

Affected assets: Web browser session (user asset), integrity of the Moodle instance (server operator asset)

Affection of protection goals: steal session tokens, cookie data or even personal information, availability of unauthorized configuration modifications, but also DOSing.

Workaround: Applying a Web Application Firewall, Content Security Policy restriction

II. EUVD-2025-18971, CVSS v.4.0: 8.7

Description: "A path traversal vulnerability exists in the Moodle LMS Jmol plugin version 6.1 and prior via the query parameter in jsmol.php. The script directly passes user input to the file_get_contents() function without proper validation, allowing attackers to read arbitrary files from the server's filesystem by crafting a malicious query value. This vulnerability can be exploited without authentication and may expose sensitive configuration data, including database credentials. Exploitation evidence was observed by the Shadowserver Foundation on 2025-02-02 UTC."

Affected assets: user account safety (user asset), OS filesystem hosting the Moodle LMS application (server operator asset)

Affection of protection goals: Ability to read any local configuration data for any web process which has read permissions, the vulnerability calls the function file_get_contents().

Workaround: URL rewriting or OS-Level Operating System Process Isolation to restrict availability of /etc/passwd.